



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-45321 TanStack npm package supply-chain compromise

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-05-27
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-45321 TanStack npm package supply-chain compromise - CVE / Vulnerability Threat Intelligence Report

Published: 2026-05-27 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-45321 TanStack npm package supply-chain compromise

1. Executive Summary

CVE-2026-45321 tracks a malicious-code supply-chain compromise affecting 42 TanStack npm packages. On 2026-05-11, between approximately 19:20 and 19:26 UTC, 84 malicious package versions were published under TanStack's legitimate trusted-publisher identity, causing install-time execution of credential-stealing malware in developer workstations and CI environments.

This is not best understood as a classic network-reachable software flaw. The strongest public evidence supports an install-time compromise path in which affected npm, pnpm, or yarn install activity exposed cloud credentials, GitHub tokens, npm tokens, Kubernetes service-account tokens, Vault tokens, and SSH keys. Because CISA added the issue to KEV on 2026-05-27, any organization that installed affected versions during the publish window should treat the host as potentially compromised and prioritize containment, credential rotation, and forensic review.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-45321
Product family	TanStack npm ecosystem packages tied to the TanStack Router repository
Weakness	CWE-506 Embedded Malicious Code
CVSS v3.1	9.6 / CRITICAL
Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H
KEV status	added by CISA on 2026-05-27 with due date 2026-06-10
Malicious publish window	2026-05-11 19:20-19:26 UTC
Affected scope	42 packages and 84 malicious versions
Example affected packages called out in the upstream advisory	@tanstack/react-router, @tanstack/router-core, @tanstack/start, @tanstack/react-start, @tanstack/solid-router, and related router / start ecosystem packages
Safe versions	package-specific patched versions are listed in the GitHub advisory; for example, @tanstack/react-router was remediated in version 1.169.9
Primary malicious artifacts	fake dependency @tanstack/setup, orphan git ref github:tanstack/router#79ac49eedf774dd4b0cfa308722bc463cfe5885c, and payload file router_init.js

3. Source Review & Confidence

Source	Contribution	Confidence
Reviewed source	CISA KEV lists `CVE-2026-45321` as `TanStack Unspecified Vulnerability`, states malicious versions were published to npm	High-confidence official exploitation-prioritization source and the original intake anchor.

Reviewed source	NVD mirrors the CNA description, records CVSS v3.1 `9.6 / CRITICAL`, maps the issue to `CWE-506`, and exposes KEV enrich	High-confidence canonical vulnerability reference and structured scoring source.
Reviewed source	The CVE Services record titles the issue `Malware in 42 @tanstack/* packages exfiltrates cloud credentials, GitHub token	High-confidence CNA-backed CVE record useful for title normalization, affected-package scope, and re
Reviewed source	GitHub's advisory documents the malicious `optionalDependencies` entry, `router_init.js` payload behavior, Session / Oxe	Highest-value technical source for mechanism, impact, indicators, and remediation detail.
Reviewed source	TanStack's postmortem states the incident was limited to the Router / Start monorepo package set, notes public detection	Official vendor context and incident-scoping source.
Reviewed source	The public incident-tracking issue captured early disclosure that several npm releases were compromised and links to ong	Valuable near-primary timeline source, but not the authoritative remediation source.
Reviewed source	StepSecurity frames the event as part of the broader Mini Shai-Hulud campaign, highlights worm-like propagation beyond T	Useful third-party research and campaign context; rely on TanStack / GitHub / NVD for the core facts

Confidence is high because the core incident narrative is consistent across official and near-primary sources: Confidence is lower on any claim that overstates downstream victim impact. Public evidence strongly supports credential theft risk and worm-like republishing behavior, but each organization's actual blast radius depends on which secrets were reachable from the install context and whether follow-on access occurred before rotation and containment.

4. Vulnerability Details

According to the GitHub advisory and mirrored NVD / CVE data, the attacker did not modify the normal npm publish workflow directly. Instead, the attacker chained three GitHub Actions abuse classes: a pull_request_target "Pwn Request" misconfiguration, cache poisoning across the fork-to-base trust boundary, and runtime extraction of an OIDC token from the GitHub Actions runner process. That chain let the attacker publish malware through TanStack's legitimate trusted-publisher path.

The poisoned packages added the following optional dependency:

```
"optionalDependencies": {
  "@tanstack/setup": "github:tanstack/router#79ac49eedf774dd4b0cfa308722bc463cfe5885c"
}
```

The referenced dependency was not a real npm package. Instead, it resolved to an orphan commit in the TanStack Router fork network. When npm processed the optional dependency, it fetched the attacker-controlled commit, installed its dependencies, ran the prepare script `bun run tanstack\_runner.js && exit 1`, and used that path to execute router_init.js from the host package tarball. The payload was approximately 2.3 MB of obfuscated JavaScript placed at package root and intentionally omitted from the package files list.

The advisory states that the payload harvested credentials from AWS IMDS and Secrets Manager, GCP metadata, Kubernetes service-account tokens, Vault tokens, .npmrc, GitHub token locations, .git-credentials, and .ssh paths. It then exfiltrated the collected data through the Session / Oxen file-upload network and enumerated additional maintainer-owned npm packages for republishing, making the incident materially more dangerous than a one-host credential stealer.

5. Attack Scenarios

1. A developer workstation installs an affected TanStack package version during the 2026-05-11 publication window, causing lifecycle-script execution and theft of locally reachable secrets.
2. A CI runner restores or resolves an affected package version, exposing cloud, GitHub, npm, or Vault credentials held by the workflow and enabling follow-on package republishing.
3. A build or release engineer with broad maintainer permissions installs an affected version, allowing the malware to enumerate packages under the maintainer identity and spread the compromise to other npm projects.
4. A victim organization rotates the directly exposed package versions but misses the underlying credential-theft impact, leaving valid GitHub, cloud, SSH, or registry credentials available for later abuse.

This makes the incident especially relevant to organizations with developer workstations that hold privileged engineering secrets, self-hosted CI, package-publishing automation, or broad OIDC trust relationships.

6. Threat Landscape & Exploitation Status

- CISA has already placed the issue in KEV, which is the clearest public signal that exploitation in the wild is established.
- CISA's KEV text and NVD enrichment both describe the issue as malicious versions being published under a trusted identity rather than a benign packaging mistake.
- TanStack's postmortem states the malicious versions were detected publicly within roughly 20 to 26 minutes and that affected releases were deprecated within the hour.
- StepSecurity describes the event as part of the broader Mini Shai-Hulud campaign and highlights worm-like propagation into other package-maintainer ecosystems.
- The incident is strategically notable because the malware abused trusted publishing and produced malicious packages through a valid release trust chain, reducing the usefulness of superficial provenance-only trust assumptions.

For defenders, the strongest takeaway is that this CVE represents a real-world developer-tooling supply-chain incident with direct credential-theft and downstream software-publishing risk, not simply a transient package-version hygiene issue.

7. Affected Products and Exposure

Direct exposure is limited to environments that installed one of the malicious package versions during or after the publish window before the versions were removed or replaced in local caches. The highest-risk exposure categories are:

- developer workstations using TanStack Router / Start ecosystem packages
- CI or release pipelines that ran package install steps against the compromised versions
- maintainers or engineering staff whose install context included npm publish rights, GitHub access tokens, cloud credentials, SSH keys, or Vault / Kubernetes secrets
- environments that cached malicious tarballs or lockfile resolutions and later reused them

The upstream advisory lists 42 affected packages with package-specific patched versions. Representative high-visibility packages include @tanstack/react-router, @tanstack/router-core, @tanstack/start, @tanstack/start-client, @tanstack/solid-router, and related devtools, SSR, and plugin packages. Organizations should review lockfiles, package-manager caches, artifact mirrors, CI logs, and software inventories rather than relying only on currently installed package versions.

8. Mitigation and Workarounds

Priority actions supported by the reviewed sources:

5. Upgrade every affected TanStack dependency to the package-specific patched version listed in the GitHub advisory.
6. Treat any host that installed an affected version on 2026-05-11 as potentially compromised; rotate all reachable GitHub, cloud, npm, Vault, Kubernetes, and SSH credentials.
7. Delete node_modules and lockfiles, then reinstall from known-good versions to prevent cached or transitive resolution of poisoned artifacts.
8. Review GitHub, cloud, package-registry, and secret-store audit logs for suspicious access, publishing activity, token use, or infrastructure actions after the exposure window.

9. Inspect packages without executing install scripts by using npm pack, extracting the tarball, checking for the malicious optional dependency entry, and looking for router_init.js at package root.
10. Use ignore-scripts as a temporary defense-in-depth control in environments where package-install trust is uncertain.
11. Block or alert on observed outbound access to the published Session / Oxen infrastructure and listed second-stage URLs where practical, while recognizing that network blocking alone does not remediate prior credential exposure.

9. Detection Engineering

Detection should focus on both host-level evidence and downstream identity misuse:

Signal	Telemetry Source	Analytic Goal
inspect tarballs or manifests for the malicious optional dependency referencing @tanstack/setup and commit 79ac49eedf774dd4b0cfa308722bc463cfe5885c	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
alert on presence of router_init.js at package root for suspect TanStack package tarballs	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
hunt for outbound connections or DNS lookups involving filev2.getsession.org, seed1.getsession.org, seed2.getsession.org, and seed3.getsession.org	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
hunt for attempts to retrieve https://litter.catbox.moe/h8nc9u.js or https://litter.catbox.moe/7rrc6l.mjs	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
review GitHub audit logs and npm publishing histories for unexpected package publishes, maintainer changes, or release activity after suspected compromise	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity

9.1 Detection Query

```
// Build and package provenance pivots for CVE-2026-45321 TanStack npm package supply-chain compromise
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("go version", "go env", "pip show", "pip list", "syft", "grype", "sbom")
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine
| order by Timestamp desc
```

9.2 Exposure / Triage Query

```
// Hunt for service instability or repeated process failures near affected build lineage
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ActionType has_any ("ProcessTerminated", "Crash", "ApplicationError") or ProcessCommandLine has_any ("panic", "fatal error")
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName
| order by Timestamp desc
```

10. Threat Hunting

Suggested hunt questions:

- Which endpoints or CI jobs installed TanStack packages on 2026-05-11, and which exact versions were resolved?
- Do any retained tarballs, lockfiles, or artifact mirrors contain the fake @tanstack/setup dependency or router_init.js payload?
- Were there any outbound connections to Session / Oxen infrastructure or the listed litter.catbox.moe URLs from developer or CI systems?
- Did any maintainer-owned npm packages show unexpected publishes shortly after a suspected install event?
- Were GitHub tokens, cloud credentials, SSH keys, or Vault tokens used anomalously after the install window by accounts associated with affected engineers or runners?
- Which developer environments combine package installation, package publication, cloud access, and secret-store access in ways that would amplify the impact of a similar future compromise?

10.1 Hunt Query

```
// Hunt for service instability or repeated process failures near affected build lineage
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ActionType has_any ("ProcessTerminated", "Crash", "ApplicationError") or ProcessCommandLine
has_any ("panic", "fatal error")
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName
| order by Timestamp desc
```

11. MITRE ATT&CK Mapping

The following ATT&CK mappings are supportable at a defender-planning level:

- T1195 Supply Chain Compromise — the malware was delivered through trusted package releases in a legitimate software distribution channel.
- T1552 Unsecured Credentials — the advisory explicitly states the payload harvested credentials from local files, metadata services, and secret-bearing paths.
- T1528 Steal Application Access Token — GitHub tokens, npm tokens, and similar application access material were explicitly targeted.
- T1041 Exfiltration Over C2 Channel — the harvested data was exfiltrated over the Session / Oxen file-upload network identified in the advisory.

These mappings describe public-advisory-supported tradecraft and should not be read as a full ATT&CK chain proven for every victim environment.

12. Validation / Lab Testing

This intake review validated the report against official and near-primary public references rather than reproducing the compromise in a lab. Analyst validation completed during this task:

- reviewed the KEV intake item and normalized intake JSON preserved in the report folder
- reviewed NVD's CVE 2.0 JSON entry for canonical description, CVSS data, CWE mapping, and KEV enrichment
- reviewed the CVE Services record for CNA title, references, and affected-package data
- reviewed GitHub advisory GHSA-g7cv-rxg3-hmpx for the install chain, indicators, package-specific patched versions, and remediation guidance
- reviewed TanStack's public postmortem for scope, timeline, and all-clear messaging
- reviewed the original TanStack issue #7383 and StepSecurity research for public-discovery timing and wider campaign context

No Lost Boys Cyber proof-of-concept execution was performed as part of this intake review.

13. Recommended Actions Summary

Priority	Owner	Action
High	Security / Platform Owners	Identify every developer endpoint, build runner, and artifact pipeline that installed

		affected TanStack package versions during the 2026-05-11 window.
Critical	Platform / Application Owners	Upgrade to package-specific patched versions and purge cached or transitive references to poisoned artifacts.
High	Security / Platform Owners	Assume reachable credentials were exposed until disproven; rotate GitHub, cloud, npm, Vault, Kubernetes, and SSH secrets accordingly.
High	Security / Platform Owners	Review publishing, audit, and cloud activity for evidence of secondary propagation or follow-on access.
High	Security / Platform Owners	Use this incident to harden developer-tooling trust boundaries, lifecycle-script policy, CI isolation, and trusted-publisher safeguards.

14. References

12. CISA KEV catalog entry for CVE-2026-45321
13. NVD entry for CVE-2026-45321
14. CVE Services record for CVE-2026-45321
15. GitHub advisory GHSA-g7cv-rxg3-hmpx, Malware in 42 @tanstack/* packages exfiltrates cloud credentials, GitHub tokens, and SSH keys
16. TanStack blog, Postmortem: TanStack npm supply-chain compromise
17. TanStack issue #7383, Several npm latest releases were compromised
18. StepSecurity research, Mini Shai-Hulud Is Back: A Self-Spreading Supply Chain Attack Compromises TanStack npm Packages